ENGINEERING RELEASE DOSSIER

v0.5.0-rc.3

Mays-Orders-AWS · Module Builder & RIS Integration

> *Ein Baukasten wird zum Vertrag: Module Builder, portable IAM und eine RIS-Integration, die im fremden Konto besteht.*

Release	v0.5.0-rc.3 (Pre-Release Candidate)
Datum	2026-10-31
Release-Basis	v0.5.0-rc.2 → 5cf50a0
Tag-Ziel	Packaging-Commit dieses Dossiers auf *main*
Repository	maynowak/mays-order-aws
Integrationsbranch	feature/mo-module-contract-ris-dev2-2026 (erhalten)
RC-Entscheidung	**GO** · Produktion: **BLOCKED** (Privacy)

Release v0.5.0-rc.3 — Mays-Orders-AWS

1. Release Overview

v0.5.0-rc.3 ist das **Module-Builder- und Integrations-Release**. Es macht aus dem bisherigen Monolithen einen wiederverwendbaren, vertraglich beschriebenen Terraform-Baustein und belegt dessen Nutzbarkeit außerhalb dieses Repos: Der **Mays-Recruiting-Intelligence-System (RIS)**-Consumer hat den gepinnten Builder in einem **fremden AWS-Testkonto** vollständig durchlaufen — Plan, Apply, Live-Tests inklusive *SQS → Worker → DynamoDB*, No-Op, Destroy und Cleanup.

Kernpunkte: Module Builder mit zwei Presets · freie Modulauswahl (*--modules*, *--with-deps*) · Policy-Gate in generierten Projekten · Orders-Service-Modulvertrag · EXTERNAL-Cognito · portable IAM-Boundary · SQS-Wildcard-Policy entfernt (F-03) · deterministische Lambda-Artefakte · 90 Builder- / 76 Lambda- / 81 Installer-Tests · RIS-AWS-E2E bestanden.

2. Änderungen seit v0.5.0-rc.2

49 Commits (46 ohne Merge), 75 Dateien, +7 628 / −119 — gegliedert nach Thema.

Module Builder

Commit	Inhalt
995f912	Foundation: *python -m module_builder*, Preset *complete*, fail-closed Preflight, Manifest mit Artefakt-Hashes
92be267	Reproduzierbares *cognito_backup.zip* (deterministischer Build)

da80271	Policy-Gate in generierte Projekte übernommen (projektspezifische resource-policy.json)
c0ac0f1 / 0e0ae71	Freie Modulauswahl *--modules* (fail-closed) und *--with-deps* (transitive Pflicht-Dependencies)
736886a	CLI-Cleanup: totes *--no-policy-check* entfernt

Terraform-Verträge & Modularisierung

Commit	Inhalt
5c70374 / 94097e2	Optionales, count-gated SQS-Recht; SQS-Wiring nur bei Auswahl
9ec7f84	Root-Outputs sqs_queue_url, sqs_queue_arn, sqs_worker_lambda_arn
4f0ab17 / 54de18d	Orders-Service-Modulvertrag (feste 7-Modul-Komposition); EXTERNAL-Cognito-Modus
9627eb2	GAP-02/06: sqs_queue_name-Output + plan-stabiles IAM-SQS-Gate

Security & Portabilität

Commit	Inhalt
ccf22a3 / a46b189	IAM-Portabilität FIX-01: Worker-Boundary portable, Builder folgt
f3e78d0	IAM-Portabilität FIX-02: kein hartcodiertes Konto im Root-Default
a2fb385	**F-03 behoben:** SQS-Resource-Policy mit Principal="*" entfernt — Zugriff nur über IAM-Identitäts-Policies

3. Module Builder

CLI-Aufrufe:

Kommando	Ergebnis
build --target ./out --project-name my-project	Standalone-Bereitstellung, 11 Module
build --target ./out --preset orders-service --project-name p	wiederverwendbares Orders-Service-Modul (7 Module)
build --target ./out --modules dynamodb iam lambda	freie Auswahl, fail-closed geprüft
build --target ./out --modules lambda --with-deps	transitive Pflicht-Dependencies ergänzt

- **Eigenständig:** kopiert Kindmodule, Root-Wiring und Artefakte; kein backend.tf, kein State, keine Repo-Abhängigkeit.
- **Fail-closed:** fehlende Artefakte brechen ab, bevor etwas geschrieben wird — keine Dummies.
- **Allowlist-Copy:** nur *.tf, deklarierte Artefakte/Quellen, Seeds; State-/Plan-/Lock-Muster nie.
- **Zielschutz:** nicht-leeres Ziel nur mit --force; gelöscht wird nie.
- **Policy-Gate eingebaut** (Exit 1 blockiert Deployments) und **Manifest** mit SHA-256 der Artefakte.

4. Terraform-Modulverträge

Preset complete — 11 Module: api, cloudtrail, cognito, cognito_backup, cognito_backup_automation, dynamodb, iam, lambda, monitoring, sqs, sqs-worker.
Preset orders-service — feste 7-Modul-Komposition (nicht abwählbar).

Vertrag	Inhalt
Inputs (6)	project_name, tags, monitoring_enabled, log_retention_days, lambda_execution_boundary, external_cognito
Outputs (20)	API (endpoint/id/stage/authorizer), DynamoDB (name/arn), SQS (url/arn/name), Worker-ARN, Lambda (name/arn/invoke), IAM (role name/arn), Cognito (pool id/arn/endpoint/client/group)
Cognito	null = MANAGED (eigener Pool) · Objekt = EXTERNAL (vorhandener Pool, keine Cognito-Ressourcen)
Modul-Modus	lokales Modul, kein Provider-Block, Artefakte über path.module, Tag-Parität via local.default_tags
Nicht im Vertrag	Monitoring, CloudTrail, Cognito-Backups, Seed, Remote-Backend, Policy-Gate-Ausführung

5. IAM-Portabilität & SQS-Security-Fix F-03

IAM: lambda_execution_boundary ist optional und defaultet im generierten Modul auf *null*; keine konto-spezifische Policy-Vorgabe mehr. Bei Setzen erzwingt eine Validierung das ARN-Format arn:aws:iam::<12 Ziffern>:policy/…. **Praxisbeleg:** RIS installierte den Stand erfolgreich in Account 262370457690 — also in einem Konto, das nicht die Quelle der früheren Defaults ist.

F-03: Vorher erlaubte eine aws_sqs_queue_policy mit Principal="*" und ohne Condition jedem Principal Senden/Empfangen/Löschen. Jetzt ist die Policy entfernt; Zugriff ausschließlich über die IAM-Identitäts-Policies (Least Privilege). Bestätigt durch lokale Code-Prüfung und den RIS-Acceptance-Report („F-03 RESOLVED (MO-Vertrag)“).

6. Lambda-Artefakte

Element	Wert
Quelle	lambda/src/index.py (Handler index.handler, Runtime python3.14)
Build	cd lambda && python3 build_zip.py → lambda/dist/lambda.zip
SHA-256	`b1018a3bd03455ede329ffaa3c66ca8115c6077741c8aad5282ee5f5fbd00e2b`
Reproduzierbarkeit	deterministischer Build; Hash je generiertem Projekt im Builder-Manifest

7. RIS-Consumer-Integration

Element	Wert
RIS-Repository	maynowak/Mays-Recruiting-Intelligence-System
Branch	feature/mo-module-installer-ris-dev2-2026 → 73965e3
Builder-Pin	1dbb0cb (Legacy-Composite-Pin 5cf50a0, abgelöst)
Integration	python -m installer.build_mays_orders_module --project-name <p> → generiertes Modul + patch_iam_sqs_gate()
Wrapper-Schutz	bricht laut ab, wenn das plan-stabile count = var.sqs_enabled ? 1 : 0 fehlt

Code-Identität zum Release: *git merge-base --is-ancestor 1dbb0cb main* ✓; *git diff -w 1dbb0cb..main -- terraform/ lambda/ module_builder/ installer/ scripts/* ist leer (ohne -w nur 10+/10− Whitespace in terraform/main.tf).

8. RIS-AWS-E2E-Evidence

Quelle: RIS-MO-RC-01-CONSUMER-ACCEPTANCE (2026-10-30) · Account 262370457690 · Region eu-central-1 · Workspace ris-dev2 · Evidence: evidence/RIS-MO-RC-01-2026/*

Test	Ergebnis
Init (Backend S3 + DDB-Lock)	PASS — Exit 0, 21 Module, aws 6.67.0
Plan	PASS — 169 add, 0 change, 0 destroy; kein Replace
Apply	PASS — Exit 0, 183 Ressourcen
Post-Deploy No-Op	PASS — „No changes“
Live-Tests T-01…T-07	7/7 PASS (Cognito, 401-Enforcement, Handler, Reader, 12 DDB-Tabellen, 6 Queues)
SQS → Worker → DynamoDB	**PASS** — Status PENDING → CONFIRMED, Queue danach leer
Destroy	PASS — Exit 0
Cleanup	CLEAN — 0 Laufzeitressourcen; nur Backend (S3-Bucket, Lock-Tabelle) erhalten

9. Lokale Regression (2026-10-31 erneut ausgeführt)

Prüfung	Ergebnis
Lambda Unit Tests	76/76 PASS
Module Builder Tests	90/90 PASS
Installer Unit Tests	81/81 PASS

terraform init / validate / fmt -check	Exit 0 / PASS / Exit 0
Generiertes orders-service-Modul (Gegencheck)	init 0 · validate PASS · fmt-check 0

10. Security & Governance

- Keine AWS-Mutationen in dieser Release-Vorbereitung; kein Apply/Destroy durch MO.
- Keine Änderung am RIS-Repository, keine Consumer-Pin-Änderung, keine Branch-Löschung.
- Keine Force-Pushes, kein Reset/Clean, keine neuen Features, kein Eingriff in Anwendungscode.
- Integrationsbranch bleibt erhalten (lokal und remote).
- Tags v0.5.0-rc.1 (f6e737b) und v0.5.0-rc.2 (5cf50a0) unverändert.

11. Bekannte Einschränkungen

- **Privacy-Produktivbetrieb: BLOCKED** — dauerhaftes Secret-Management und Rotation fehlen (5–8 PT).
- **Keine allgemeine Multi-Account-Produktionsreife belegt:** Ein Testkonto belegt Portabilität, nicht beliebige Konten (Quotas, SCPs, Boundaries bleiben Consumer-Verantwortung).
- **F-01:** explizit gesetzter Boundary-ARN ist nicht cross-account-portabel; Default ist null.
- **EXTERNAL-Cognito:** id/arn/group liefern null; optionale Zusatzfelder offen; MANAGED→EXTERNAL-Migration nicht automatisiert.
- **RIS-Pin** steht auf 1dbb0cb — Nachziehen rein kosmetisch (code-identisch).
- **Builder liefert kein Backend**; Konsumenten konfigurieren ihr eigenes Remote-Backend.
- **Collision-Preflight** bleibt namensbasiert (Phase 2 offen); S3 mays-orders-ci-artifacts-dev ungeklärt.
- **GitHub-Veröffentlichung** ist menschlich: Tag und Release nicht durch den Agenten erstellt.

12. Nächste Schritte

- Menschliche Freigabe → Tag v0.5.0-rc.3 auf den Packaging-Commit, Push des Tags.
- GitHub-Pre-Release mit diesen Release Notes anlegen.
- RIS: Builder-Pin optional auf den Release-Commit ziehen.
- Secrets Manager + Rotation → Production-Privacy-Gate.
- Collision-Preflight Phase 2 und finale Abnahme v0.5.0.